

簡易勒索病毒實作及探討

資工四 S10859050 郭宇倫

資工四 S10859045 呂建篁

資工四 S10859048 陳睦善

摘要

由於網路普及化及物聯網和雲端服務的整合，常見的物聯網設備使用簡化的作業系統且無法安裝掃毒引擎，並且管理者缺乏持續系統更新，這容易引起資安疑慮，因為這些設備存在的漏洞可能遭受駭客攻擊，進而導致企業或個人的隱私資訊外洩或損失，加上近幾年來的勒索病毒演進，它們可能可以通過防毒軟體的偵測。因此本組將針對透過在虛擬機上實作簡易的勒索病毒並針對可能的感染途徑進行探討分析。

1. 介紹

勒索病毒是一種惡意程式軟體，專門將本機儲存重要檔案加密後要求支付贖金才能解開檔案。駭客開發惡意程式目的是為了勒索牟利。常見的可能感染勒索病毒的途徑通常為，垃圾郵件、惡意廣告、殭屍網路或惡意軟體安裝工具等，而駭客製作的勒索病毒會隨著人類網路的生活習慣去考量調整勒索病毒演進，加上人類很容易忽略病毒對資安所造成的風險，這也是病毒無法被根除的原因之一。勒索病毒一旦被執行，就會搜尋本機與網路上儲存裝置來尋找可加密的檔案，它會攻擊認為能對您企業足以造成損失或個人重要的檔案，包括復原資料的備份檔案、企業機密等。以著名的 WannaCry 勒索病毒為例，WannaCry 被認為利用美國國家安全局的「永恆之藍」工具以攻擊 Microsoft Windows 作業系統的電腦，被針對的副檔名共有 176 種，包括 Microsoft Office、資料庫、壓縮檔、多媒體檔案和各種程式語言常用的副檔名。「永恆之藍」利用了某些版本的微軟伺服器訊息區塊（Windows Server Message Block, SMB）協定中的漏洞，而當中最嚴重的漏洞是允許遠端電腦執行惡意程式碼，接著再將真正的勒索病毒檔案送入受害系統，它會用 .WNCRY 副檔名來對相關檔案進行加密。趨勢科技於 2017 年 4 月中首次監測到勒索病毒，最初是透過網路釣魚攻擊誘使使用者從 Dropbox 下載惡意程式，後來，趨勢科技發現這一個勒索病毒「WannaCry/Wcry」已進化為結合 SMB 伺服器漏洞 EternalBlue 與新勒索病毒家族的變種。

2. 虛擬環境簡介

- 虛擬機: Oracle VM VirtualBox
- 作業系統: Window10 64 位元
- 記憶體: 2048MB
- 處理器: 2CPUs

說明:

由於本組實作的作業為勒索病毒，為了避免感染本地的電腦，因此下載免費的虛擬機軟體 Oracle VM VirtualBox，透過在虛擬機建立測試的環境來測試實作出的勒索病毒。

虛擬機優點:

1. 獨立性：我們所建造的每個虛擬機器都擁有自己獨立的環境，且可以根據自己的需要建立特定的作業系統及應用程式，也不會相互衝突。
2. 完全性：透過管理 Host 的資源（CPU、RAM、Storage）並依照每台虛擬機器的需求分配，讓實體機器的資源能被充分的使用。
3. 易修復性：可以利用 VM 的快照（Snapshot），為自己的機器建立多個還原點，以實踐災難恢復（Disaster Recovery）。

虛擬機缺點:

1. 服務版本更新困難：若要更新部署在虛擬機器上的服務，勢必要將服務停止在進行更新，但如果更新的機器數量較為龐大，將會耗費過多人力資源與時間。
2. 修復程序較為耗時：雖然遇到重大錯誤時可透過 Snapshot 復原，但發生錯誤需要重啟時，也需要人力重啟，若多部機器需要重啟，工作量勢必是非常龐大且耗時。

3. 實作與探討

Part I.生成 2048 位長度的 RSA 密鑰並將私鑰和公鑰保存到文件中

RSA (Rivest-Shamir-Adleman) 是一種非對稱加密演算法，於 1977 年由 Ron Rivest、Adi Shamir 和 Leonard Adleman 共同提出。它是當今最廣泛使用公鑰加密演算法之一。在 RSA 中，使用者擁有一對公鑰和私鑰。公鑰可公開分享給他人，而私鑰則必須保密。RSA 的運作原理是基於數學中兩個重要問題：大數分解和模數取離散對數。由於兩個問題非常困難，目前並不存在最佳解決的演算法，促使 RSA 成為一種相對安全可靠的加密方法。使用 RSA 進行加密時，發送方使用接收方公鑰來對數據加密，接收方則使用私鑰解密。因為私鑰只有接收方擁有，所以只有接收方能夠解密，以確保數據的安全性。

Part II.使用加密演算法對指定目錄下的文件進行加密

首先使用遞迴掃描指定目錄下所有文件，並依文件類型判別是否需要加密，並返回一個包含所有文件的列表。接收要加密的文件和公鑰作為輸入，並使用 RSA 和 AES 加密演算法對文件進行加密。加密後，它會將原始文件刪除並將加密後的數據保存到以".GiveMeMoney"為副檔名的新文件中，並顯示倒數計時，具體步驟如下：

- A. 讀取文件資料
- B. 創造公鑰，並生成一個隨機的密鑰
- C. 使用公鑰加密密鑰
- D. 使用被密鑰和 AES 演算法對文件資料進行加密
- E. 將加密後的資料數據保存到文件中，並移除原始文件

Part III.解密

用於破解具特定自訂名".GiveMeMoney"的文件，將使用儲存在私鑰文件中的私鑰來解密已被加密的特定文件，透過遞迴掃描指定目錄並返回所有文件的列表。將欲破解的文件路徑和私鑰路徑作為輸入，並使用 AES 和 RSA 演算法進行解密。具體步驟如下：

- A. 讀取私鑰
- B. 從加密文件中讀取數據和密鑰
- C. 使用私鑰破解被加密的密鑰
- D. 使用已解密的密鑰和 AES 演算法對被加密數據進行解密
- E. 將解密後的數據保存，文件名會添加".decrypted"或".txt"自訂名

4. Demo

➤ <https://www.youtube.com/watch?v=oMzuwllE2rQ>

5. 結論

本組針對勒索病毒進行實作，從這一系列的探討可以得知勒索病毒會利用人性的疏失進行勒索，甚至病毒也會隨著時間演進產生出新型的病毒來對使用者構成資訊安全的威脅，有的病毒更善於偽裝來躲避防毒軟體偵測，使這一類的病毒更加難以防範，針對勒索病毒所帶來的影響損失，本組一致認為不予理會來路不明的信件、不點擊不明連結、不隨意下載不可靠不信任的文件及軟體等，以避免造成無法挽救重要文件資料或個人私人資訊外洩而造成更多方面的損失，並且除上述措施要做好之外，需定期更新防毒軟體，否則防毒軟體若沒有隨著新型病毒演進來做更新提前預防，很可能該病毒就會藉由潛在的漏洞進行攻擊並向使用者勒索贖金。

參考文獻

- [1] <https://ithelp.ithome.com.tw/m/articles/10254342>
- [2] <https://infosecwriteups.com/how-to-make-a-ransomware-with-python-c4764f2014cf>
- [3] https://www.youtube.com/watch?v=YcEotl3Jo_g
- [4] https://www.trendmicro.com/zh_tw/what-is/ransomware.html
- [5] https://www.cc.ntu.edu.tw/chinese/epaper/0038/20160920_3807.html
- [6] <https://github.com/febimudiyanto/python-project/tree/main/simple-ransomware>
- [7] <https://applealmond.com/posts/5171>
- [8] <https://ithelp.ithome.com.tw/articles/10311598>
- [9] https://www.trendmicro.com/zh_tw/what-is/ransomware.html
- [10] <https://zonetech.tw/blogs/what-is-ransomware/>
- [11] <https://ess.site.nthu.edu.tw/p/404-1351-118887.php?Lang=zh-tw>